



**CENTRO DE EDUCAÇÃO
PROFISSIONAL DE MARICÁ
UNIVASSOURAS**

Segurança de Dados, Backup e Versionamento de Software

Profª Isabel Valentim

Disciplina: Práticas Extensionistas Integradoras V



Objetivos da Aula

- Compreender conceitos de segurança de dados
- Aplicar boas práticas no Front-end e Back-end
- Conhecer bibliotecas e APIs de segurança
- Entender estratégias de backup e versionamento



PROBLEMÁTICAS

Uma startup criou um sistema de delivery.

Problemas encontrados:

- Senhas sem criptografia
- Sem backup automático
- API sem autenticação
- Todos desenvolvem direto na branch main
- Sem logs

Perguntas:

- Quais riscos existem?
- Como resolver?
- Quais ferramentas poderiam ajudar?

Por que Segurança Importa?

- Vazamento de dados
- Ataques ransomware
- Roubo de credenciais
- LGPD e responsabilidade jurídica

Princípios da Segurança

- Confidencialidade
- Integridade
- Disponibilidade
- Tríade CIA

A Tríade CIA é um modelo fundamental para a segurança da informação, representando Confidencialidade, Integridade e Disponibilidade

Front-end x Back-end

- Front-end: interface e navegador
- Back-end: APIs e banco de dados
- Segurança deve existir nos dois lados

Principais Vulnerabilidades

- SQL Injection
- Cross-Site Scripting (XSS)
- Exposição de senhas
- Upload inseguro
- Tokens expostos

OWASP Top 10

- Broken Access Control
- Cryptographic Failures
- Injection
- Security Misconfiguration
- Insecure Design

Segurança no Front-end

- Validar formulários
- Usar HTTPS
- Sanitizar entradas
- Proteger rotas

Validação no Front-end

- Evita dados inválidos
- Melhora experiência do usuário
- Não substitui validação do Back-end

Autenticação Segura

- JWT
- OAuth 2.0
- OpenID Connect
- MFA

Segurança no Back-end

- Validar dados no servidor
- Controle de permissões
- Logs de auditoria
- HTTPS/TLS

SQL Injection

- Nunca concatenar queries
- Usar Prepared Statements
- Utilizar ORM

Criptografia de Senhas

- Nunca usar texto puro
- bcrypt
- Argon2
- PBKDF2

Rate Limit

- Proteção contra brute force
- Controle de requisições
- Redução de ataques automatizados

Segurança em APIs

- Autenticação obrigatória
- Controle de acesso
- Logs e monitoramento
- Versionamento da API

Upload Inseguro de Arquivos

- Validar extensão
- Validar MIME Type
- Limitar tamanho
- Usar armazenamento seguro

O que é MIME Type?

- Identificação real do tipo do arquivo
- image/png
- application/pdf
- Evita arquivos maliciosos

Tokens Expostos

- Nunca salvar segredos no Front-end
- Usar variáveis de ambiente
- Adicionar .env ao .gitignore

Controle de Permissões

- RBAC
- Usuário comum $\neq$ administrador
- Middleware de autorização

OBS: (RBAC - Role-Based Access Control) - Controle de Acesso Baseado em Função

Dados sem Criptografia

- Usar HTTPS
- Criptografar backups
- Evitar tráfego em texto puro

Backup de Sistemas

- Proteção contra falhas
- Proteção contra ransomware
- Recuperação de desastres

Tipos de Backup

- Full Backup
- Incremental
- Diferencial

Regra 3-2-1

- 3 cópias
- 2 mídias diferentes
- 1 cópia fora do ambiente



Ferramentas de Backup

- Veeam
- Acronis
- AWS Backup
- Google Cloud Backup

Backup de Banco de Dados

- mysqldump
- pg_dump
- MongoDB Backup Tools

Versionamento de Software

- Histórico de alterações
- Trabalho em equipe
- Recuperação de versões

Git e GitHub

- Commits
- Branches
- Pull Requests
- Code Review



Além do GitHub

- GitLab
- Bitbucket
- Azure DevOps
- AWS CodeCommit

Boas Práticas com Git

- Commits pequenos
- Mensagens claras
- Proteção da branch main

Estratégias de Branch

- Git Flow
- GitHub Flow
- Feature branches



Versionamento Semântico

- MAJOR.MINOR.PATCH
- 2.5.1
- Correções e releases

Versionamento Pós-Entrega

- Correção de bugs
- Atualizações de segurança
- Monitoramento contínuo

DevSecOps

- Development + Security + Operations
- Segurança integrada ao desenvolvimento
- Automação

DevSecOps é a integração da segurança em todas as etapas do ciclo de vida de desenvolvimento de software

Pipeline Moderno

- Commit
- Testes automatizados
- Scanner de segurança
- Deploy

Deploy (que significa "implantar" em português) é o processo de colocar um sistema, aplicativo ou site no ar, disponibilizando-o para que os usuários finais possam acessá-lo e utilizá-lo

Estudo de Caso

- API sem autenticação
- Sem backup
- Senhas sem hash
- Todos usam branch main

Conclusão

- Segurança desde o início
- Backup é essencial
- Versionamento reduz erros
- DevSecOps é tendência